Planteamiento del proyecto: Guardián IA

Alumno: Antonio De Mateo Bodegas

Asignatura: Proyectos de Ciberseguridad

Título provisional: Guardián IA, una herramienta para usar la inteligencia artificial de forma segura

1. Por qué he elegido este tema

Hoy casi todo el mundo usa ChatGPT, Gemini o Claude para estudiar o trabajar, y yo también. El problema es que la mayoría lo usamos sin pensar en los riesgos. Pegamos documentos del trabajo con datos de clientes, nos fiamos de respuestas que a veces la IA se inventa y le pasamos archivos sin saber qué llevan dentro.

Las empresas grandes ya tienen herramientas para controlar esto, pero son caras y están pensadas para equipos de seguridad. Una persona normal o una pyme no tiene nada sencillo que le avise. Por eso quiero hacer una herramienta que proteja a quien usa la IA sin saber de ciberseguridad y que le explique los riesgos con palabras que entienda.

Además, quiero que el proyecto me sirva para aprender a fondo cómo funcionan los modelos de lenguaje, cuáles son sus riesgos y cómo se protegen los datos.

2. La idea: Guardián IA

Guardián IA es un programa que se instala en el ordenador y se pone en medio entre el usuario y la IA que esté usando. Funciona como un portero que revisa lo que sale, lo que entra y los archivos que se le pasan a la IA. Tendrá cuatro partes:

1. **Escudo de datos.** Antes de enviar un mensaje, revisa si lleva datos personales o sensibles (DNI, IBAN, contraseñas, claves de acceso, nombres de clientes). Si los encuentra, avisa y ofrece cambiarlos por etiquetas como [PERSONA_1], y después los vuelve a poner en la respuesta.
2. **Verificador de respuestas.** Separa la respuesta de la IA en afirmaciones, busca cada una en fuentes y le pone un color: verde si está confirmada, amarillo si no se encuentra y rojo si alguna fuente la contradice. También comprueba que los enlaces que da la IA existen de verdad.
3. **Aduana de documentos.** Antes de pasarle a la IA un PDF, una web o un correo, mira si tiene texto oculto o contenido pensado para manipular a la IA en vez de para que lo lea una persona. Si es así, lo marca como sospechoso y explica por qué.
4. **Revisión del software de IA (extra si da tiempo).** Revisa lo relacionado con IA que hay instalado en el ordenador: extensiones del navegador que se hacen pasar por ChatGPT, conectores de asistentes con más permisos de los necesarios y archivos de modelos descargados de internet que pueden llevar código malicioso escondido.

Todo lo que detecte lo explicará en lenguaje sencillo, con un semáforo y una frase de qué hacer.

3. Objetivos

Objetivo general: desarrollar una herramienta de código abierto que funcione en local y ayude a personas sin conocimientos de ciberseguridad a usar asistentes de IA sin poner en riesgo sus datos y sin fiarse de información falsa.

Objetivos específicos:

- Estudiar los riesgos principales de las aplicaciones con IA, tomando como base el OWASP Top 10 for LLM Applications.
- Detectar datos sensibles antes de que salgan del ordenador.
- Comprobar la fiabilidad de las respuestas de la IA comparándolas con fuentes.
- Detectar documentos manipulados antes de que los lea la IA.
- Medir con pruebas cuánto acierta cada módulo y cuántas falsas alarmas da. Publicar la
- herramienta en GitHub con su documentación.

4. Herramientas parecidas

Ninguna de las herramientas que he encontrado junta estas funciones en un solo programa local pensado para usuarios sin formación. Ahí está el hueco que quiero cubrir.

Herramienta	¿Usa IA?	Qué hace	Diferencia con mi idea	Relación
Microsoft Purview, Nightfall	Sí	Evitan fugas de datos en empresas, también hacia chatbots	De pago y para equipos de seguridad	Mi herramienta sería una alternativa sencilla y gratuita
Microsoft Presidio	Parcial	Librería que detecta y anonimiza datos personales	Es para programadores, no una aplicación	Complementaria, la usaré por dentro
Herramienta	¿Usa IA?	Qué hace	Diferencia con mi idea	Relación

Lakera Guard, LLM Guard, Prompt Guard	Sí	Filtran lo que entra y sale de un chatbot	Pensadas para empresas que crean chatbots, no para quien los usa	Complementarias
Perplexity	Sí	Buscador con IA que cita fuentes	No revisa las respuestas de otra IA	Distinta
Vectara HHEM, Guardrails AI	Sí	Detectan cuándo una IA se inventa cosas	Librerías técnicas sin interfaz	Complementarias
ModelScan, picklescan	No	Revisan archivos de modelos de IA en busca de código peligroso	Solo hacen esa tarea	Complementarias (módulo extra)

Para la memoria final revisaré con más detalle el estado actual, la licencia y el alcance de cada una.

5. Papel de la IA en el proyecto

Tipo de planteamiento: las dos cosas. La herramienta se desarrolla con ayuda de IA y además usa IA en su funcionamiento.

Por qué aporta valor la IA: un DNI o una tarjeta se detectan con reglas, pero hay cosas que las reglas no resuelven bien: saber si una frase es un dato confidencial de una empresa, separar una respuesta en afirmaciones o explicar un riesgo a alguien que no sabe nada del tema. La IA se usará solo para eso, y lo que se pueda hacer con reglas se hará con reglas.

Uso de IA durante el desarrollo: usaré Claude Code como asistente de programación. También me he apoyado en IA para ordenar las ideas de este planteamiento. Mi forma de trabajar será esta: defino cada tarea y sus pruebas, la IA me propone código, yo lo reviso y lo entiendo antes de aceptarlo, y lo subo a Git. Para validar el código usaré tests automáticos y herramientas de análisis de seguridad como bandit y semgrep. Llevaré un registro semanal de lo que ha hecho la IA y lo que he hecho yo.

Componentes con IA, modelo y datos que se envían:

- **Escudo de datos:** modelo local con Ollama. No se envía nada fuera, porque no tendría sentido mandar a otra IA los datos que quiero proteger.
- **Verificador:** modelo local o la API de Claude, a elegir. Solo se envían las afirmaciones de la respuesta, ya limpias de datos sensibles.

- **Aduana de documentos:** modelo local que clasifica el contenido.

Riesgos del propio componente de IA:

- **Prompt injection:** los documentos que revisa la herramienta podrían intentar engañar a su propia IA. Por eso se tratarán siempre como datos y nunca como órdenes, y la decisión final combinará reglas fijas con la opinión de la IA.
- **Fuga de información:** los datos sensibles se procesarán siempre en local.
- **Control de acciones:** la IA de la herramienta no podrá ejecutar nada, solo avisar y proponer. La decisión la toma siempre el usuario.
- **Errores de la IA:** mediré las falsas alarmas y los fallos de cada módulo para saber cuánto se puede confiar en él.

6. Cómo funciona



funcionamiento general · 3 puntos con IA

El usuario sigue usando la IA como siempre. El Guardián revisa lo que sale y los documentos que adjunta y, cuando vuelve la respuesta, la contrasta con fuentes antes de enseñarle el resultado con un semáforo.

7. Tecnologías, hardware y coste

Lenguaje principal: Python, como se recomienda en la asignatura. Además usaré:

- FastAPI para el programa local que hace de intermediario y para el panel de avisos.
- Microsoft Presidio y expresiones regulares para detectar datos personales.
- Ollama para ejecutar modelos de IA en local.
- Una extensión sencilla de navegador en JavaScript para avisar dentro de la web del chatbot.
- SQLite para guardar el historial, pytest para las pruebas y GitHub para el código.

Hardware: [mi ordenador: modelo, RAM y si tiene tarjeta gráfica]. Con 16 GB de RAM es suficiente, y con una tarjeta gráfica de 8 GB o más los modelos locales irán más rápido. No necesito comprar nada.

Coste: en modo local el coste es 0 €. Si uso la API de Claude para el verificador, cada comprobación cuesta unos céntimos, y calculo menos de 30-50 € en todo el proyecto.

8. Planificación

El trabajo está pensado para 12 semanas. Si el proyecto dura cuatro meses, el tiempo extra irá a la revisión del software de IA.

Semanas	Qué voy a hacer
1-2	Estudiar las herramientas parecidas y los riesgos de la IA, preparar el entorno y diseñar la arquitectura
3-4	Escudo de datos
5-6	Verificador de respuestas
7-8	Aduana de documentos
9	Unir los módulos, extensión del navegador y panel
10	Pruebas y medición de resultados
11	Documentación y publicación en GitHub
12	Memoria final y presentación

Próxima entrega: un primer avance práctico, con el diseño de la arquitectura y una primera versión del escudo de datos funcionando.